



SA.4 — E2.4: DOCUMENTACIÓN DE SEGURIDAD

Índice

1. Introducción.....	2
2. Objetivo	2
3. Alcance.....	2
4. Descripción General del Ecosistema	2
5. Validación de event.origin en BroadcastChannel documentada y aplicada en código	3
5.1 Validación del origen de los mensajes.....	3
5.2 Canal de auditoría de seguridad	3
6. Cumplimiento de la Ley Federal de Protección de Datos Personales (LFPDPPP)	4
6.1 Tratamiento de los datos personales.....	4
7. Aviso de Privacidad	6
8. Plan de Retención de Datos.....	6
8.1 Conservación y eliminación de la información	6
9. Checklist de Seguridad de la Progressive Web App.....	7
10. Conclusiones	10
Justificación del uso de Inteligencia Artificial	11

1. Introducción

La presente documentación tiene como finalidad describir las medidas de seguridad implementadas dentro del ecosistema de dispositivos inteligentes desarrollado para el sistema de gestión de citas de la barbería. Este ecosistema está conformado por una aplicación móvil para clientes, una aplicación Wear OS, una Progressive Web App (PWA) para Smart TV y un backend desarrollado con NestJS conectado a una base de datos PostgreSQL.

El documento se centra en las políticas de seguridad implementadas para proteger la información personal de los usuarios, asegurar la comunicación entre los dispositivos y cumplir con los requisitos establecidos en la rúbrica de la Evaluación 2 de la asignatura Desarrollo para Dispositivos Inteligentes.

2. Objetivo

Documentar las medidas de seguridad implementadas en el ecosistema del proyecto, describiendo el tratamiento de los datos personales, las políticas de protección de la información, los mecanismos de seguridad utilizados por la Progressive Web App y el cumplimiento de los requisitos establecidos para la evaluación correspondiente.

3. Alcance

Esta documentación abarca las medidas de seguridad implementadas en el backend, la aplicación móvil, la aplicación Wear OS y la Progressive Web App para Smart TV. Asimismo, incluye las políticas relacionadas con la protección de datos personales, el tratamiento de la información de los clientes y los mecanismos utilizados para garantizar una comunicación segura entre los diferentes componentes del sistema.

4. Descripción General del Ecosistema

El sistema desarrollado permite que un cliente gestione sus citas mediante una aplicación móvil, consulte información relevante desde un dispositivo Wear OS y visualice información sincronizada en una Progressive Web App diseñada para Smart TV. Toda la información es administrada por un backend desarrollado con NestJS y almacenada en una base de datos PostgreSQL.

Para garantizar la seguridad del ecosistema se implementaron mecanismos de autenticación mediante JWT, cifrado de contraseñas utilizando bcrypt, protección de rutas mediante Guards, almacenamiento seguro de credenciales en Flutter Secure Storage y políticas de seguridad para la PWA, como Content Security Policy y Service Worker.

5. Validación de event.origin en BroadcastChannel documentada y aplicada en código

5.1 Validación del origen de los mensajes

Con el objetivo de fortalecer la seguridad de la Progressive Web App para Smart TV, se implementó un canal interno de comunicación utilizando la API **BroadcastChannel**, el cual permite registrar eventos de auditoría generados durante la interacción del usuario con la interfaz. Este mecanismo fue incorporado para cumplir con los requerimientos de seguridad establecidos en la evaluación, garantizando que únicamente los mensajes provenientes del origen autorizado sean procesados por la aplicación.

Durante la inicialización de la aplicación se crea un canal denominado `barberia_tv_security`, el cual funciona como un medio de comunicación interno para el registro de eventos relacionados con la navegación de la interfaz.

Antes de procesar cualquier mensaje recibido, la aplicación obtiene el origen actual mediante la propiedad `window.location.origin` y compara dicho valor con el origen del mensaje recibido (`event.origin`). En caso de detectar que el mensaje proviene de un origen distinto al autorizado, la aplicación bloquea inmediatamente su procesamiento y registra un mensaje de advertencia en la consola del navegador, evitando que información proveniente de aplicaciones o sitios externos sea interpretada por el sistema.

Este procedimiento permite prevenir intentos de comunicación provenientes de orígenes no autorizados y garantiza que únicamente los eventos generados por la propia aplicación sean considerados válidos.

Captura de código de evidencia:

```
this.securityChannel.onmessage = (event: MessageEvent) => {  
  const allowedOrigin = window.location.origin;  
  if (event.origin && event.origin !== allowedOrigin) {  
    console.error('⚠ Transmisión de mensaje bloqueada: Intento de violación de origen desde', event.origin);  
    return;  
  }  
  console.log('[Seguridad TV] Evento de auditoría local validado con éxito:', event.data);  
};
```

5.2 Canal de auditoría de seguridad

Además de validar el origen de los mensajes, el canal de comunicación es utilizado como un mecanismo de auditoría interna dentro de la aplicación para Smart TV.

Cada vez que el usuario interactúa con la interfaz mediante el control remoto (o las teclas de dirección durante las pruebas en el navegador), la aplicación genera automáticamente un registro de auditoría utilizando el método

broadcastSecurityLog(). Dicho registro contiene información relevante sobre la acción realizada, incluyendo el tipo de evento, la tarjeta seleccionada y la fecha y hora en la que ocurrió la interacción.

Los eventos registrados permiten llevar un seguimiento de la navegación realizada por el usuario dentro de la interfaz, facilitando tareas de monitoreo y depuración durante el desarrollo del sistema.

Entre las acciones registradas por el canal de auditoría se encuentran:

- Cambio de foco entre las tarjetas mediante las teclas direccionales (Arrow Up, Arrow Down, Arrow Left y Arrow Right).
- Selección de un elemento utilizando la tecla **Enter/OK**.
- Cambio del recurso multimedia mostrado como fondo de la aplicación.
- Registro de la fecha y hora en que ocurrió cada interacción.

La información transmitida por el canal de auditoría corresponde únicamente a eventos internos de navegación y no contiene datos personales de los usuarios, por lo que su utilización no representa un riesgo para la privacidad de la información administrada por el sistema.

```
191     }  
192 }  
193  
194 broadcastSecurityLog(actionType: string) {  
195     this.securityChannel.postMessage({  
196         action: actionType,  
197         targetCard: this.focusedIndex,  
198         timestamp: new Date().toISOString()  
199     });  
200 }
```

6. Cumplimiento de la Ley Federal de Protección de Datos Personales (LFPDPPP)

6.1 Tratamiento de los datos personales

El sistema desarrollado cumple con los principios establecidos por la **Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP)** mediante la identificación de los datos personales necesarios para la operación del servicio y la definición de su finalidad.

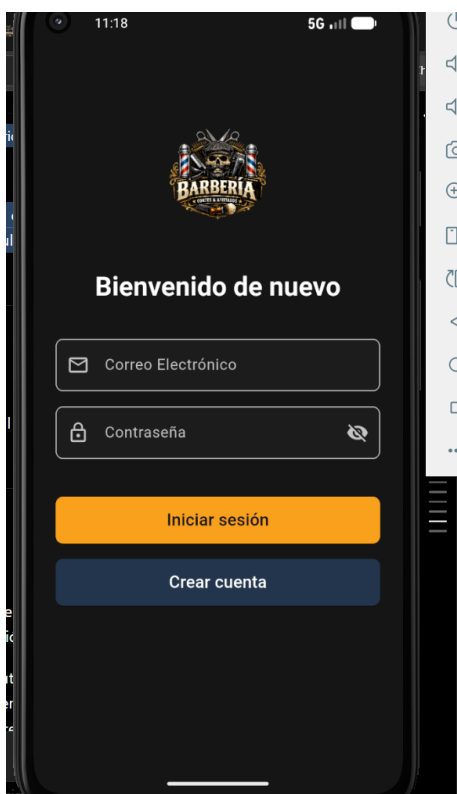
Durante el proceso de registro y utilización de la aplicación únicamente se solicitan los datos indispensables para la administración de citas dentro de la barbería. Estos datos son utilizados exclusivamente para la prestación del servicio y no son compartidos con terceros sin autorización del titular.

Los principales datos personales tratados por el sistema se muestran en la siguiente tabla.

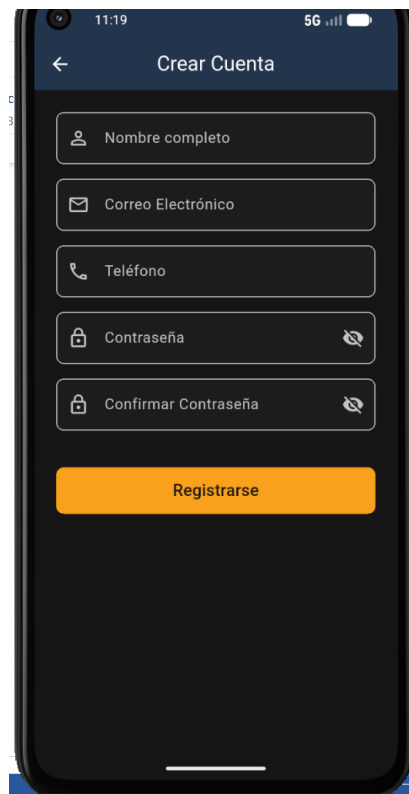
Dato personal	Finalidad
Nombre completo	Identificar al cliente durante la gestión de citas y mostrar la información correspondiente dentro de la aplicación.
Correo electrónico	Permitir el inicio de sesión y establecer un medio de contacto con el usuario.
Número telefónico	Facilitar la comunicación con el cliente en caso de cambios, confirmaciones o cancelaciones de citas.
Información de citas	Administrar las reservaciones realizadas por el usuario y mantener un historial de atención.

El acceso a esta información se encuentra restringido mediante autenticación con JWT y autorización basada en roles, permitiendo que únicamente los usuarios autorizados puedan consultar o modificar la información correspondiente.

Login:



Registro:



7. Aviso de Privacidad

El sistema de gestión de citas para barbería es responsable del tratamiento de los datos personales proporcionados por los usuarios durante el registro y utilización de la aplicación.

Los datos personales recabados tienen como finalidad principal permitir la autenticación de los usuarios, la administración de citas, la visualización de información relacionada con los servicios contratados y la sincronización de información entre los dispositivos que conforman el ecosistema.

Los datos personales no serán utilizados para fines distintos a los establecidos sin el consentimiento previo del titular y no serán compartidos con terceros ajenos al funcionamiento del sistema.

El usuario podrá ejercer en cualquier momento sus derechos de Acceso, Rectificación, Cancelación y Oposición (ARCO), solicitando la modificación o eliminación de su información personal mediante los medios de contacto establecidos por el responsable del sistema.

Asimismo, el proyecto implementa mecanismos técnicos destinados a proteger la confidencialidad de la información, tales como el cifrado de contraseñas mediante bcrypt, autenticación utilizando JSON Web Tokens y almacenamiento seguro de credenciales dentro de la aplicación móvil.

8. Plan de Retención de Datos

8.1 Conservación y eliminación de la información

Con el propósito de mantener la integridad de la información y evitar el almacenamiento innecesario de datos personales, el sistema establece políticas de conservación para cada tipo de información utilizada durante su operación.

La siguiente tabla resume el periodo de conservación definido para los principales datos del sistema.

Tipo de información	Tiempo de conservación	Método de eliminación
Usuarios registrados	Mientras la cuenta permanezca activa	Eliminación lógica al solicitar la baja de la cuenta.
Historial de citas	Hasta un año después de su registro	Eliminación lógica y posterior depuración de la base de datos.
Tokens de autenticación	Hasta su expiración	Eliminación automática al cerrar sesión o vencer el token.
Datos temporales del Wear OS	Solo durante la sesión activa	Eliminación automática al finalizar la conexión Bluetooth.

Estas políticas permiten reducir la exposición de información sensible y mantener únicamente los datos necesarios para el correcto funcionamiento del sistema.

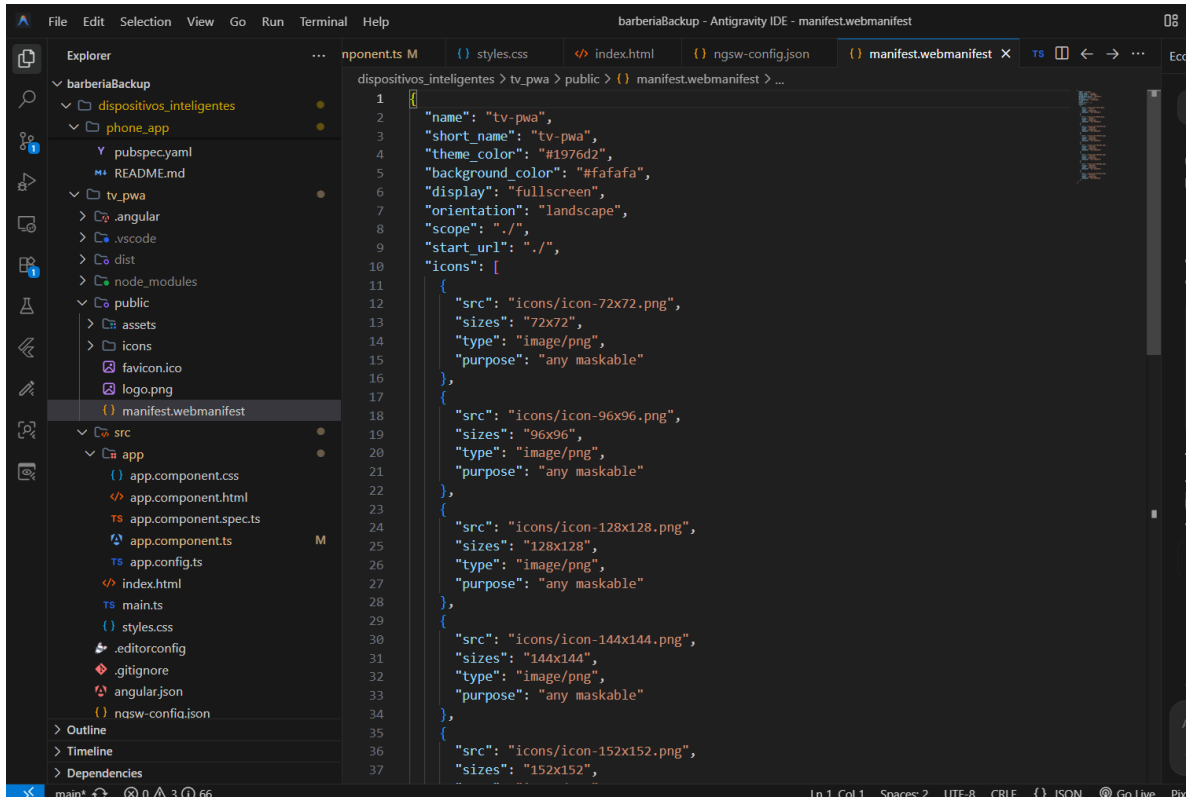
9. Checklist de Seguridad de la Progressive Web App

Con el objetivo de proteger la Progressive Web App y garantizar un funcionamiento seguro dentro del ecosistema, se implementaron diferentes mecanismos de seguridad durante su desarrollo.

Medida de seguridad	Implementación
Content Security Policy (CSP)	Configurada mediante la etiqueta <meta> del proyecto para restringir las conexiones únicamente a los orígenes autorizados.
HTTPS	Todas las comunicaciones con la aplicación se realizan mediante conexiones seguras utilizando HTTPS.
Service Worker	Implementado para permitir el funcionamiento offline y el almacenamiento seguro de recursos en caché.
Manifest Web App	Configurado con orientación horizontal, pantalla completa e íconos propios del proyecto.
Variables de entorno	Las credenciales sensibles permanecen fuera del repositorio mediante archivos .env.
Control de acceso	Implementado mediante JWT y autorización basada en roles.
Protección de contraseñas	Contraseñas cifradas utilizando bcrypt antes de almacenarse en la base de datos.

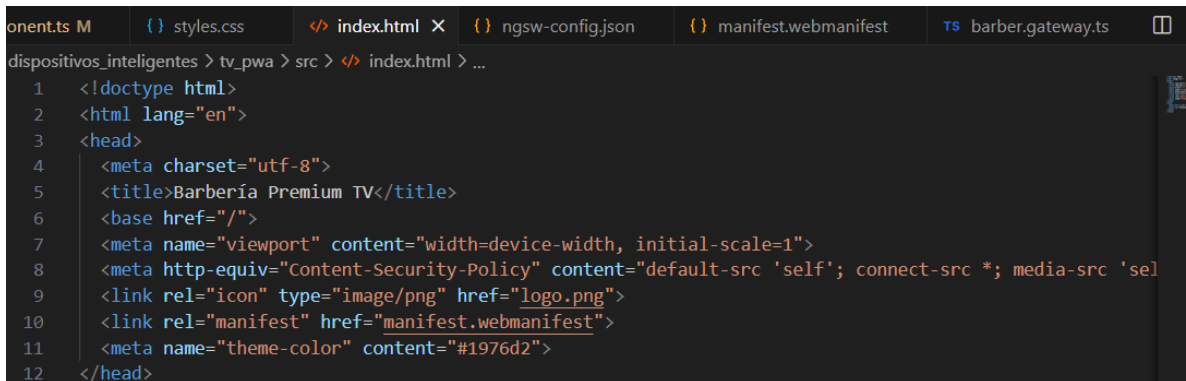
En conjunto, estas medidas fortalecen la seguridad del ecosistema, reducen la posibilidad de accesos no autorizados y permiten ofrecer un entorno confiable para los usuarios.

Evidencia:



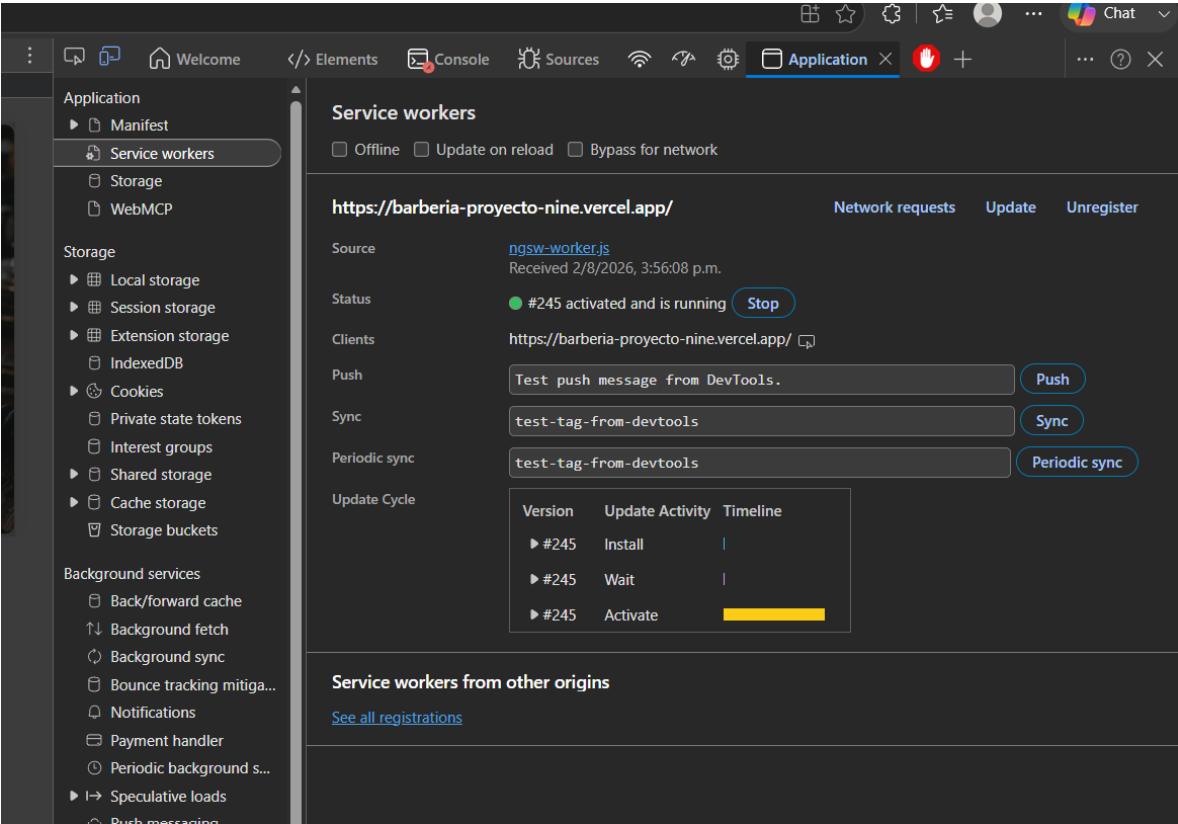
The screenshot shows the Visual Studio Code editor with the 'barberiaBackup' project open. The Explorer panel on the left shows the project structure, with the 'manifest.webmanifest' file selected under the 'public' directory. The main editor displays the content of 'manifest.webmanifest' in JSON format. The file is located at 'dispositivos_inteligentes > tv_pwa > public > manifest.webmanifest'.

```
1 {
2   "name": "tv-pwa",
3   "short_name": "tv-pwa",
4   "theme_color": "#1976d2",
5   "background_color": "#fafafa",
6   "display": "fullscreen",
7   "orientation": "landscape",
8   "scope": "./",
9   "start_url": "./",
10  "icons": [
11    {
12      "src": "icons/icon-72x72.png",
13      "sizes": "72x72",
14      "type": "image/png",
15      "purpose": "any maskable"
16    },
17    {
18      "src": "icons/icon-96x96.png",
19      "sizes": "96x96",
20      "type": "image/png",
21      "purpose": "any maskable"
22    },
23    {
24      "src": "icons/icon-128x128.png",
25      "sizes": "128x128",
26      "type": "image/png",
27      "purpose": "any maskable"
28    },
29    {
30      "src": "icons/icon-144x144.png",
31      "sizes": "144x144",
32      "type": "image/png",
33      "purpose": "any maskable"
34    },
35    {
36      "src": "icons/icon-152x152.png",
37      "sizes": "152x152",
```



The screenshot shows the Visual Studio Code editor with the 'barberiaBackup' project open. The Explorer panel on the left shows the project structure, with the 'index.html' file selected under the 'src' directory. The main editor displays the content of 'index.html' in HTML format. The file is located at 'dispositivos_inteligentes > tv_pwa > src > index.html'.

```
1 <!doctype html>
2 <html lang="en">
3 <head>
4   <meta charset="utf-8">
5   <title>Barberia Premium TV</title>
6   <base href="/">
7   <meta name="viewport" content="width=device-width, initial-scale=1">
8   <meta http-equiv="Content-Security-Policy" content="default-src 'self'; connect-src *; media-src 'self';>
9   <link rel="icon" type="image/png" href="logo.png">
10  <link rel="manifest" href="manifest.webmanifest">
11  <meta name="theme-color" content="#1976d2">
12 </head>
```



10. Conclusiones

La implementación de mecanismos de seguridad dentro del ecosistema desarrollado permitió garantizar la protección de la información administrada por las aplicaciones que conforman el proyecto. A lo largo del desarrollo se integraron diferentes estrategias enfocadas en proteger tanto el acceso al sistema como la comunicación entre dispositivos y el tratamiento responsable de los datos personales.

La autenticación mediante JSON Web Token, el cifrado de contraseñas utilizando bcrypt, la autorización basada en roles, el almacenamiento seguro de credenciales en la aplicación móvil y las políticas de seguridad implementadas en la Progressive Web App contribuyen a reducir riesgos asociados al acceso no autorizado y a la exposición de información sensible.

Asimismo, el cumplimiento de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares permitió establecer criterios claros para el manejo de la información de los usuarios, incorporando un aviso de privacidad, políticas de retención de datos y medidas orientadas a preservar la confidencialidad de la información.

En conjunto, las medidas implementadas proporcionan un ecosistema seguro para la interacción entre la aplicación móvil, el dispositivo Wear OS, la Progressive Web App para Smart TV y el backend del sistema, cumpliendo con los requisitos de seguridad establecidos para la Evaluación 2 y fortaleciendo la confiabilidad general de la solución desarrollada.

Justificación del uso de Inteligencia Artificial

Durante la elaboración del software y la documentación del proyecto se utilizó una herramienta de Inteligencia Artificial (ChatGPT, OpenAI) como apoyo en la detección y solución de problemas relacionados con el código, análisis de errores, consulta de posibles soluciones técnicas y mejora de la redacción del contenido.

La Inteligencia Artificial fue utilizada como una herramienta complementaria durante el proceso de desarrollo, pero no realizó la programación del sistema ni sustituyó el análisis, la lógica de implementación, las pruebas o la validación del funcionamiento del software. La arquitectura, desarrollo, decisiones técnicas y comprobaciones del sistema fueron realizadas por el autor del proyecto.

En la elaboración del documento, la información y contenido técnico fueron redactados previamente por el autor con base en el trabajo realizado, evidencias obtenidas y pruebas ejecutadas. Posteriormente, la Inteligencia Artificial fue utilizada únicamente para apoyar en la corrección de redacción, ortografía, estructura y claridad del texto, manteniendo la responsabilidad del contenido final en el autor.